

Theory Notes

1. Vulnerability Scanning Techniques

Network Scanning

Network scanning is the process of identifying active hosts, open ports, and running services on a network. It helps security professionals understand the attack surface of a target system.

Tool Used: Nmap

Example:

Shell

```
nmap -sV 192.168.56.101
```

Benefits:

- Identifies open ports
- Detects running services
- Helps discover potential vulnerabilities

Application Scanning

Application scanning focuses on identifying vulnerabilities in web applications and services.

Tool Used: Nikto

Example:

Shell

```
nikto -h http://192.168.56.101
```

Common Findings:

- Outdated software versions
- Missing security headers
- Directory listing vulnerabilities
- Weak server configurations

Authenticated vs Unauthenticated Scanning

Authenticated Scanning

Authenticated scanning uses valid credentials to access the target system.

Advantages:

- More accurate results
- Better visibility into system configuration
- Lower false positives

Unauthenticated Scanning

Unauthenticated scanning simulates an external attacker without valid credentials.

Advantages:

- Real-world attacker perspective
- Identifies externally exposed vulnerabilities

CVSS Scoring

CVSS (Common Vulnerability Scoring System) is used to measure the severity of vulnerabilities.

Score Range	Severity
0.0 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10.0	Critical

Example:

VSFTPD Backdoor – CVSS 10.0 (Critical)

False Positives

A false positive occurs when a security scanner reports a vulnerability that does not actually exist.

Validation Methods:

- Manual verification
- Version checking
- Configuration review
- Controlled exploitation testing

2. Penetration Testing Techniques

Reconnaissance

Reconnaissance is the information gathering phase of penetration testing.

Activities:

- WHOIS Lookup
- Technology Fingerprinting
- Service Enumeration
- Asset Discovery

Tools:

- Nmap
- WhatWeb
- Wappalyzer

Scanning

Scanning identifies vulnerabilities and exposed services.

Tools:

- Nmap

- Nikto
- OpenVAS

Objectives:

- Discover open ports
- Identify services
- Detect vulnerabilities

Exploitation

Exploitation attempts to gain unauthorized access by leveraging identified vulnerabilities.

Tools:

- Metasploit
- SQLMap

Examples:

- VSFTPD Backdoor Exploit
- SQL Injection Attack

Post-Exploitation

Post-exploitation activities assess the impact of a successful compromise.

Activities:

- Evidence Collection
- Privilege Escalation
- Data Access Verification
- System Enumeration

Reporting

Reporting documents findings, risks, and remediation recommendations.

Components:

- Executive Summary

- Technical Findings
- Risk Ratings
- Remediation Steps

PTES Methodology

PTES (Penetration Testing Execution Standard) is a structured penetration testing framework.

Phases:

1. Pre-Engagement Interactions
2. Intelligence Gathering
3. Threat Modeling
4. Vulnerability Analysis
5. Exploitation
6. Post-Exploitation
7. Reporting

Benefits:

- Standardized testing approach
- Improved documentation
- Better communication of results

3. Exploit Development Basics

Buffer Overflow

A buffer overflow occurs when more data is written to memory than allocated.

Impact:

- Program crashes
- Arbitrary code execution
- System compromise

Example:

Writing excessive input into a fixed-size buffer.

SQL Injection

SQL Injection occurs when user input is improperly validated and is executed as part of a database query.

Example Payload:

```
SQL
' OR 1=1--
```

Impact:

- Unauthorized database access
- Data modification
- Data theft

Prevention:

- Prepared statements
- Parameterized queries
- Input validation

Cross-Site Scripting (XSS)

XSS allows attackers to inject malicious scripts into web pages viewed by other users.

Example Payload:

```
HTML
<script>alert('XSS')</script>
```

Impact:

- Session hijacking
- Credential theft
- Malicious redirection

Prevention:

- Output encoding

- Input sanitization
- Content Security Policy (CSP)

Mitigations

ASLR (Address Space Layout Randomization)

Randomizes memory locations to make exploitation difficult.

WAF (Web Application Firewall)

Filters malicious web requests before they reach the application.

Patch Management

Regular software updates remove known vulnerabilities and improve security.

Secure Coding Practices

Developers should validate inputs, use parameterized queries, and follow secure development standards.

Conclusion

Vulnerability Assessment and Penetration Testing (VAPT) helps organizations identify, validate, and remediate security weaknesses before they can be exploited by attackers. Effective scanning, penetration testing, exploit analysis, and reporting are critical components of a strong cybersecurity program.